

1.1–1.5 · CIA Triad, Security Attacks, Services & Mechanisms

CIA Triad + Additional Concepts

Concept Description

Information is not disclosed to unauthorised individuals. Includes data

Confidentiality

confidentiality and privacy (individuals control their own information).

Protects against improper modification of data or systems. Includes data

Integrity

integrity and system integrity.

Ensures timely and reliable access to systems and data. Directly targeted by

Availability

DoS attacks.

Authenticity Assurance that an entity or message is genuine and verifiable.

Actions can be uniquely traced to an entity. Supports auditing and non-

Accountability

repudiation.

Security Attacks (X.800)

Passive Attacks

Feature Details

Definition Learn or use information without affecting the system

Detection Difficult to detect

Data Change No modification occurs

Examples Eavesdropping, traffic analysis, release of message contents

Prevention Encryption

Active Attacks

Feature Details

Definition Alter system resources or affect operations

Detection Easier to detect

Prevention Difficult to completely prevent

Examples Masquerade, replay, message modification, denial of service

Security Services (X.800)

- Authentication
- Access Control
- Data Confidentiality
- Data Integrity

Non-repudiation

Security Mechanisms

Specific Security Mechanisms

Encipherment

- Digital signatures
- Access controls
- Data integrity checks
- Authentication exchange
- Traffic padding
- Routing control
- Notarisation

Pervasive Security Mechanisms

Trusted functionality

- Security labels
- Event detection
- Security audit trails
- Security recovery

Exam Tips

Passive vs Active Attacks

Passive Attack Active Attack

No data modification Data is modified or false data inserted

Hard to detect Hard to prevent

Examples: traffic analysis, eavesdropping Examples: replay, masquerade, DoS

Replay Attack Prevention

1. Timestamps

- Reject messages older than a permitted threshold.

2. Challenge/Response

- Uses a fresh nonce each session, making captured messages useless.
-

1.6 · Fundamental Security Design Principles

Principle Explanation

Keep security simple and small to reduce bugs and

Economy of Mechanism

complexity.

Fail-safe Defaults Default setting is deny access unless permission is granted.

Complete Mediation Every access must be checked against access controls.

Open Design Security should rely on secret keys, not secret algorithms.

Separation of Privilege Access should require multiple conditions (e.g., 2FA).

Least Privilege Users/processes get only minimum required privileges.

Least Common Mechanism Minimise shared resources to reduce covert channels.

Psychological Acceptability Security should remain user-friendly.

Isolation Separate users, processes, and critical systems.

Layering (Defense in

Depth)

Multiple overlapping protections are used.

1.7 · Attack Surfaces and Attack Trees

Attack Surface Categories

Category Description Examples

Network Attack Vulnerabilities accessible over Open ports, exposed protocols,

Surface networks wireless APs

Software Attack Vulnerabilities in software or OS APIs, web services, input

Surface code processing flaws

Human Attack Phishing, social engineering,

Vulnerabilities caused by people

Surface insider threats

Attack Trees

Definition

A hierarchical structure representing techniques for exploiting vulnerabilities to achieve an attack goal.

Structure

Component Description

Root Node Attacker's main objective

Child Nodes Sub-goals or conditions

Leaf Nodes Specific concrete attacks

Logic Types

Node Type Meaning

AND Node All child conditions must succeed

OR Node Any one child condition is sufficient

Example

Root Goal:

Steal customer credit card data

Possible Paths:

- Hack the database directly
- Intercept traffic
- Compromise an employee

Sub-goal under "Hack the database":

- SQL Injection AND bypass firewall
-

1.8 · Model for Network Security

General Model

The model contains four key components:

1. Message
2. Security transformation
3. Secret key
4. Two communicating principals

Components of the Model

Principal A (Sender)

- Sends a secure message to Principal B.
- Applies a security transformation such as:

Encryption

Digital signature

Trusted Third Party

Used to establish trust or distribute keys.

Example Purpose

KDC (Kerberos) Shared key distribution

CA (PKI) Certificate validation

Security Channel

- Communication may occur over an insecure network.
- Security depends on transforming the message securely before transmission.

Opponent

Type Description

Passive Opponent Observes communication only

Active Opponent Modifies or injects messages

Design Tasks in Network Security

1. Design secure transformation algorithms
2. Generate secret keys
3. Distribute and share keys securely
4. Develop protocols using these mechanisms

Applications of the Model

Technology Secret Used

Symmetric Encryption Shared key

Public-key Encryption Receiver's public key

Digital Signatures Sender's private key

Authenticated Key Exchange Session/shared keys

1.9 · Security Standards

Importance of Standards

Security standards ensure interoperability between systems by defining common:

- Protocols
- Algorithms
- Key sizes
- Security procedures

Without standards, secure communication between different vendors would not be possible.

Key Standards Bodies

Organisation Role / Standards

Publishes FIPS and SP 800-series. Defined AES, SHA-3, NIST Cybersecurity NIST

Framework. FIPS 140-2/3 certifies cryptographic modules.

ISOC / IETF Produces RFCs. Standards include TLS, IPsec, SSH, DNSSEC.

ITU-T Produces X-series Recommendations such as X.509 and X.800.

ISO/IEC Publishes ISO/IEC 27001, 27002, and Common Criteria (15408).

IEEE Defines IEEE 802.11 (Wi-Fi), 802.11i (WPA2), and 802.1X.

2.1 · Web Security Threats and Security Approaches Web Security Threats

Threat Type Description Example

Man-in-the-middle alters financial

Integrity Threat Modification of data or transmissions data during transmission

Confidentiality Packet sniffing on unencrypted HTTP,

Unauthorised disclosure of information

Threat session token theft

Threat Type Description Example

Denial of Service Overwhelms services so legitimate
HTTP flood attack against web server
(DoS) users cannot access them
Authentication Attacker pretends to be a legitimate
Phishing, session hijacking, IP spoofing
Threat entity

Three Levels of Security

Level Technology Description

Security at IP layer. Transparent to applications. Protects all traffic

Network Layer IPsec

between hosts/networks.

Transport

SSL/TLS Runs above TCP and below applications. Most common for HTTPS.

Layer

Application Security implemented within specific applications. Most tailored but
S/MIME

Layer requires per-app implementation.

2.2 · TLS Architecture TLS Protocol Components

TLS Record Protocol (Lower Layer)

Functions Performed

1. Fragment application data (max 2¹⁴ bytes)
2. Optional compression (removed in TLS 1.3)
3. Add MAC/HMAC for integrity
4. Encrypt data using symmetric encryption
5. Add TLS header
6. Transmit securely

Receiver Operations

1. Decrypt
2. Verify MAC
3. Decompress
4. Reassemble data
5. Deliver to application

Security Provided

Protection Method

Confidentiality Encryption

Integrity MAC/HMAC

Change Cipher Spec (CCS) Protocol

Feature Description

- 1
Message Size Single byte with value
Purpose Signals that negotiated cipher settings become active
Timing Sent after handshake key negotiation
TLS 1.3 Status Retained only for backward compatibility

Alert Protocol

Purpose

Communicates TLS warnings and errors.

Alert Structure

Field Description

Level Warning (1) or Fatal (2)
Description Specific alert code

Important Alert Codes

Alert Meaning

close_notify
Normal secure closure
unexpected_message
Invalid protocol message

Alert Meaning

bad_record_mac
Integrity verification failed
decryption_failed

Decryption unsuccessful
record_overflow
Record exceeded allowed size
handshake_failure
Negotiation failed
bad_certificate
Invalid certificate
certificate_expired
Certificate expired
certificate_unknown
Unknown certificate authority
illegal_parameter
Invalid parameter used

Fatal Alert Behaviour

- Immediately terminates connection
 - Session state deleted
-

TLS Handshake Protocol — 4 Phases

Phase 1 — Establish Security Capabilities

ClientHello

Client sends:

- Maximum TLS version
- Random value
- Session ID
- Supported cipher suites
- Compression methods

ServerHello

Server sends:

- Selected TLS version
- Server random value
- Selected cipher suite
- Compression method

Result

Both parties agree on algorithms and security parameters.

Phase 2 — Server Authentication & Key Exchange

Messages

Message Purpose

Certificate Sends X.509 certificate chain
ServerKeyExchange Sends DH/ECDHE parameters
CertificateRequest Optional client certificate request
ServerHelloDone Indicates server finished phase

Phase 3 — Client Authentication & Key Exchange

Messages

Message Purpose

Certificate Optional client certificate
ClientKeyExchange Sends pre-master secret or DH public value
CertificateVerify Proves client owns private key

CertificateVerify

Contains a digital signature over all handshake messages exchanged so far.

Phase 4 — Finish

Sequence

1. Client sends ChangeCipherSpec
2. Client sends Finished message
3. Server sends ChangeCipherSpec
4. Server sends Finished message

Result

Secure application data transfer begins.

Heartbeat Protocol (RFC 6520)

Purpose

- Keeps TLS connection alive
- Confirms peer availability
- Avoids performing full handshake repeatedly

Operation

Step Description

HeartbeatRequest Sender transmits payload + claimed length
HeartbeatResponse Receiver echoes payload back

Heartbleed Vulnerability (CVE-2014-0160)

Feature Details

Vulnerability OpenSSL Heartbeat implementation flaw
Cause Claimed payload length larger than actual payload
Result Server leaked process memory contents
Data Exposed Private keys, passwords, session data
Fixed In OpenSSL 1.0.1g

SSL/TLS Attacks

Attack Description Fix

BEAST (2011) Exploited CBC mode in TLS 1.0 Use TLS 1.1+ or GCM
POODLE (2014) SSLv3 padding oracle attack Disable SSLv3
CRIME / BREACH Exploited TLS compression Remove compression
Heartbleed Memory leak through Heartbeat Patch OpenSSL
Downgrade Attacks Forced weaker protocol/cipher TLS 1.3, TLS_FALLBACK_SCSV
MITM Certificate Attack Fake certificate interception Proper certificate validation

TLS 1.3 Improvements

Improvement Description

Removed Weak Crypto Removed RC4, DES, 3DES, MD5, SHA-1, export ciphers
Faster Handshake Reduced from 2 RTT to 1 RTT
0-RTT Resumption Allows immediate data sending in resumed sessions

Forward Secrecy Mandatory Uses only ECDHE

Encrypted Handshake Handshake messages encrypted after ServerHello

Exam Tips

Phase III of TLS Handshake

Client Authentication & Key Exchange

Steps:

1. Optional Certificate message
2. ClientKeyExchange
3. CertificateVerify

Purpose:

- Authenticate client
- Establish shared secret

Heartbleed Vulnerability

A flaw in OpenSSL's Heartbeat implementation where an attacker could request more bytes than actually sent, causing the server to leak sensitive memory contents such as:

- Private keys
 - Passwords
 - Session information
-

2.3 · HTTPS — Connection Initiation and Closure HTTPS Overview

HTTPS = HTTP running over TLS.

HTTPS Provides

- Encryption
 - Server authentication
 - Optional client authentication (mutual TLS)
-

HTTPS Connection Initiation

Step Process

```
https://example.com
1 User enters
2 Browser opens TCP connection to port 443
3 TLS handshake occurs
4 Server certificate validated
```

Step Process

```
5 Session keys established
6 Browser sends encrypted HTTP request
7 Server sends encrypted HTTP response
```

HTTPS Connection Closure

Secure Closure Process

Both client and server exchange:

- close_notify alerts

before terminating TCP connection.

```
close_notify
```

Why Matters

Prevents truncation attacks where an attacker forcibly terminates the TCP connection to cut off data silently.

What HTTPS Encrypts

Encrypted Notes

```
URL path & query Hidden from attackers
HTTP headers Includes cookies
HTTP body Fully encrypted
Session cookies Protected
```

What HTTPS Does NOT Hide

Visible Information Notes

```
Destination IP address Still visible
Packet sizes/timing Traffic analysis possible
DNS queries Visible unless DoH/DoT used
SNI hostname (TLS 1.2) Visible during handshake
```

2.4 · SSH — Protocol Layers SSH Architecture

SSH runs over TCP port 22 and contains three protocol layers.

1. Transport Layer Protocol

Functions

- Server authentication
- Confidentiality

Integrity protection

Key exchange

Features

Feature Description

```
Port TCP 22
Key Exchange Diffie-Hellman
Server Authentication RSA/ECDSA host keys
Output Shared session key
```

2. User Authentication Protocol

Authenticates the CLIENT to the server.

Authentication Methods

Method Description

```
Public-key Client signs challenge using private key
Password Password sent securely inside SSH tunnel
Host-based Trust based on client machine identity
```

3. Connection Protocol

Multiplexes multiple logical channels over one SSH connection.

Channel Types

Channel Purpose

Session Interactive shell / remote command
direct-tcpip Local port forwarding
forwarded-tcpip Remote port forwarding
X11 Graphical forwarding

SSH Port Forwarding (Tunneling)

Local Port Forwarding

```
ssh -L 8080:internal-server:80 user@jump-host
```

Purpose

Access internal services through an SSH tunnel.

Remote Port Forwarding

```
ssh -R 9090:localhost:3000 user@server
```

Purpose

Expose local service through remote server.

Dynamic Port Forwarding (SOCKS Proxy)

```
ssh -D 1080 user@server
```

Purpose

Creates SOCKS proxy and tunnels TCP traffic via SSH.

Exam Tips

SSH User Authentication Methods

1. Public-key authentication
 2. Password authentication
 3. Host-based authentication
-

3.1 · Remote User Authentication Principles Two-Step Authentication Process

Step Description

User presents an identifier such as username, smart card, or biometric scan. The

Identification

system locates the claimed identity.

User provides evidence proving ownership of the identity such as password, PIN,

Verification

private key signature, or fingerprint.

Four Means of Authentication

Authentication Factor Examples Advantages Weaknesses

Password, PIN, Cheap and Guessing, phishing,

Something You Know

passphrase simple keylogging

Smart card, OTP token, Stronger

Something You Possess Loss or theft possible

YubiKey security

Something You Are (Static Cannot be Privacy concerns, hard

Fingerprint, iris, retina

Biometrics) forgotten to revoke

Something You Do (Dynamic Voice pattern, keystroke Can vary due to stress

Hard to imitate

Biometrics) dynamics or illness

Mutual Authentication

Both parties authenticate each other.

Example How It Works

TLS Server authenticated via certificate; client optionally authenticated

Kerberos Server proves it decrypted the service ticket correctly

Purpose

Prevents impersonation attacks in both directions.

3.2 · Remote Authentication Using Symmetric Encryption Symmetric Key Authentication

Uses a **shared secret key**

Requires a trusted Key Distribution Centre (KDC) for scalability

- Prevents every pair of users from manually sharing keys
-

Needham–Schroeder Symmetric Key Protocol

Purpose

Establish a secure session key between two users using a KDC.

Protocol Flow

Step 1 — Request to KDC

A → KDC

Contains:

- Identity of A
- Identity of B
- Nonce N1

Purpose

Request session with B and prevent replay attacks.

Step 2 — KDC Responds

KDC → A

Encrypted using A's long-term key.

Contains:

- K_s
- Session key
- Original nonce N1
- B's identity
- Ticket encrypted for B

Ticket Contents

Encrypted using B's key:

- Session key K_s
- Identity of A

Step 3 — Ticket Forwarding

A → B

A forwards ticket to B.

Result

B decrypts ticket and obtains:

- Session key K_s
- Identity of A

Step 4 — Challenge from B

B → A

Encrypted with K_s .

Contains:

- Nonce N2

Purpose

B proves possession of session key.

Step 5 — Response from A

A → B

Encrypted with K_s .

Contains:

$N2 - 1$

Purpose

A proves possession of session key and freshness.

Weakness of Needham–Schroeder

Weakness Description

Replay Attack Old captured tickets can be replayed to B

Timestamp Fix

Solution

Include timestamps in tickets.

Result

B rejects tickets older than an allowed threshold.

Requirement

Synchronized clocks across systems.

Impact

This weakness directly influenced the design of Kerberos V5.

Exam Tip

Main Weakness of Needham–Schroeder

Replay attacks using old tickets.

Fix

Use timestamps and ticket expiration.

3.3 · Kerberos in Depth Kerberos Overview

Developed at MIT under Project Athena.

Uses a trusted third party:

Key Distribution Centre (KDC)

The KDC contains:

1. Authentication Server (AS)
 2. Ticket Granting Server (TGS)
-

Kerberos Login Flow

Step 1 — User Login

User enters password.

Client Action

Derives secret key from password hash.

Step 2 — Request to Authentication Server

Client → AS

Sends:

Username only

Important

Password is never transmitted.

Step 3 — AS Response

AS → Client

Contains:

1. Client-TGS session key encrypted with user's secret key
2. Ticket Granting Ticket (TGT) encrypted with TGS key

Step 4 — Client Decrypts Response

Client decrypts session key using password-derived key.

Result

TGT cached locally.

Step 5 — Request Service Ticket

Client → TGS

Sends:

- TGT
- Authenticator
- Requested service name

Authenticator

Timestamp encrypted using TGS session key.

Step 6 — TGS Issues Service Ticket

TGS → **Client**

Contains:

- Service ticket
- Client-service session key

Step 7 — Access Service

Client → **Service Server**

Sends:

- Service ticket
- New authenticator

Server Action

Verifies ticket and timestamp.

Result

Access granted.

Kerberos V5 Improvements Over V4

Improvement Description

Address Independence Supports multiple network address types
Flexible Ticket Lifetimes Renewal and forwarding supported

Removed Double Encryption More efficient than V4

Algorithm Flexibility Supports multiple cryptographic algorithms
Pre-authentication Prevents password guessing attacks

Exam Tip

How Kerberos Distributes Session Keys

The KDC generates session keys and encrypts them using each party's long-term secret key.

Important

Session keys are never transmitted in plaintext.

3.4 · Remote Authentication Using Asymmetric Encryption Public-Key Authentication

Each user possesses:

- Public key

Private key

Principle

Authentication proves ownership of the private key.

Mutual Authentication Using Public Keys

Step 1 — A Sends Nonce

A → **B**

Sends:

- Random nonce N_a

Step 2 — B Responds

B → **A**

Sends:

- N_a encrypted with A's public key
- New nonce N_b encrypted with B's public key

Result

A decrypts N_a successfully → authenticates B.

Step 3 — A Responds

A → **B**

Sends:

- N_b encrypted with B's public key

Result

B decrypts N_b successfully → authenticates A.

Session Key Exchange

Either side may generate session key K_s and send it encrypted with the other party's public key.

Purpose

Subsequent communication uses faster symmetric encryption.

Advantages of Asymmetric Authentication

Advantage Explanation

No KDC Required Eliminates dependency on trusted third party
Scalability Requires only one key pair per user
Non-repudiation Digital signatures prove message origin

Disadvantages

Disadvantage Explanation

Slower Performance Much slower than symmetric encryption
PKI Requirement Requires certificates and Certificate Authorities

Practical Use

Most systems:

1. Use asymmetric cryptography for authentication and key exchange
2. Switch to symmetric encryption for bulk data

Example

TLS handshake + AES session encryption.

Exam Tip

Why Asymmetric Encryption Is Not Used for Bulk Data

Public-key operations are computationally expensive.

Therefore

Asymmetric crypto:

- Authentication
- Key exchange

Symmetric crypto:

- Bulk encryption
-

3.5–3.8 · Federated Identity, NAC, EAP, and IEEE 802.1X

Federated Identity

Enables identity portability across multiple organisations.

Example

University login used to access:

- Microsoft 365
 - Online library databases
-

Key Protocols

Protocol Purpose

SAML Enterprise identity federation
OAuth 2.0 Delegated authorization
OpenID Connect Authentication layer on OAuth 2.0

Identity Management (SSO)

Single Sign-On (SSO)

Authenticate once and access multiple authorised systems.

Benefits

- Reduces password fatigue
 - Fewer help desk requests
 - Centralised identity control
-

Network Access Control (NAC) Three NAC Elements

Component Function

Access Requestor User/device requesting access
Policy Server Evaluates credentials and security posture
Network Access Server Enforces allow, quarantine, or deny decision

Extensible Authentication Protocol (EAP)

Definition

Framework supporting multiple authentication methods.

Important

EAP itself is NOT an authentication method.

Common EAP Methods

Method Description

EAP-TLS Certificate-based authentication
PEAP Password authentication inside TLS tunnel
EAP-TTLS Tunneled TLS authentication
EAP-PSK Pre-shared key authentication

IEEE 802.1X

Definition

Port-based Network Access Control standard.

Three Roles in 802.1X

Role Description

Supplicant Client device
Authenticator Switch or wireless access point

Authentication Server Usually RADIUS server

Authentication Process

1. Port initially blocked
 2. Client allowed to send only EAPOL frames
 3. Authentication occurs
 4. Port opened after successful authentication
-

4.1 · VPN Types and Protocols VPN Overview

A Virtual Private Network (VPN) creates a secure logical communication channel over a shared public network.

Term Meaning

Virtual No dedicated physical connection
Private Access restricted and data protected

Types of VPNs

Remote Access VPN

Description

Individual remote users securely connect to a corporate network.

Features

- Encrypted tunnel between user device and VPN gateway
- User appears logically inside corporate LAN

Common Use

Remote work / telecommuting

Site-to-Site VPN (Intranet VPN)

Description

Connects multiple office branches securely.

Features

- Replaces expensive leased lines
- Encryption performed by gateway routers
- End devices unaware of VPN

Common Use

Corporate branch connectivity

Extranet VPN

Description

Connects an organisation to external business partners.

Features

- Restricted access to selected resources only
- Prevents full internal network exposure

Common Use

Supplier and partner integration

VPN Protocols

Non-Secure VPN Protocols

Protocol Description Security Weakness

MPLS	Label-based traffic isolation	No encryption
GRE	Encapsulates IP packets	No encryption or authentication
L2TP	Tunnels Layer 2 frames	No built-in security

Important Notes

MPLS

- Security depends on trusting the ISP
- Common in enterprise WANs

GRE

- Supports multicast traffic
- Often combined with IPsec

L2TP

- Usually deployed as L2TP/IPsec
-

Secure VPN Protocols

Protocol Features

IPsec	Authentication, integrity, confidentiality
SSL/TLS VPN	Browser-based secure remote access

SSL/TLS VPN Advantages

Easier deployment

- Often no dedicated client software required
 - Popular for remote access VPNs
-

Exam Tip

VPN Protocols Without Confidentiality

1. MPLS
2. GRE
3. L2TP

Reason:

None provide encryption by themselves.

4.2–4.6 · IPsec, IKE, and Cryptographic Suites IPsec Overview

IPsec provides:

- Confidentiality
- Integrity
- Authentication
- Replay protection

Layer

Operates at the Network Layer (IP Layer).

IPsec Core Protocols AH (Authentication Header)

Feature Description

IP Protocol Number	51
--------------------	----

Feature Description

Confidentiality	■ No encryption
Integrity	■ Yes

Authentication ■ Yes
Replay Protection
■ Optional
NAT Compatibility ■ Not compatible

Why AH Fails with NAT

AH authenticates portions of the IP header.

Problem

NAT changes IP addresses → authentication fails.

ESP (Encapsulating Security Payload)

Feature Description

IP Protocol Number 50
Confidentiality ■ Encryption provided
Integrity ■
Yes
Authentication ■ Yes
Replay Protection ■
Yes
NAT Compatibility ■ Supported with NAT-T

ESP Characteristics

- Most widely used IPsec protocol
 - Protects payload data
 - Outer IP header can remain unchanged
-

IPsec Modes Transport Mode

Characteristics

Feature Description

Protection Scope Payload only
IP Header Visibility Original IP header visible
Typical Use Host-to-host VPN

Packet Structure

IP Header | ESP/AH | TCP/UDP/Data

Tunnel Mode

Characteristics

Feature Description

Protection Scope Entire original IP packet
Original IP Header Encrypted and hidden
Outer Header Contains gateway addresses
Typical Use Site-to-site VPN

Packet Structure

New IP Header | ESP | Original IP Header | TCP/UDP/Data

Security Associations (SA) Definition

A one-way logical security connection.

SA Identification

An SA is uniquely identified by:

1. SPI (Security Parameters Index)
 2. Destination IP Address
 3. Security Protocol (AH or ESP)
-

SPI (Security Parameters Index)

Purpose

32-bit value used by the receiver to identify the correct Security Association.

SPI Lookup Process

Receiver combines:

SPI

- Destination IP

- Security protocol

to locate the correct SA in the SAD.

SAD — Security Association Database

Stores active SA information.

Stored Information

Parameter Purpose

Sequence numbers	Replay protection
Algorithms	Encryption/integrity methods
Keys	Cryptographic keys
SA lifetime	Expiration management
Mode	Transport or tunnel

SPD — Security Policy Database

Defines how packets should be handled.

SPD Actions

Action Meaning

BYPASS	Send packet without IPsec
DISCARD	Drop packet
PROTECT	Apply IPsec protection

Internet Key Exchange (IKE) Purpose of IKE

Automatically:

Negotiates cryptographic algorithms

Exchanges keys

- Establishes IPsec Security Associations

Port Used

UDP port 500

Current Version

IKEv2 (RFC 7296)

IKEv2 Phases Phase 1 — IKE_SA_INIT

Functions

- Establishes IKE Security Association
- Negotiates algorithms
- Performs Diffie–Hellman exchange
- Generates shared secret

Result

Creates secure encrypted control channel.

Phase 2 — IKE_AUTH

Functions

- Authenticates identities
- Establishes first Child SA
- Negotiates traffic selectors

Authentication Methods

Method Description

Certificates	Public-key authentication
Pre-shared Keys	Shared secret authentication

Child SA

The actual IPsec Security Association used for protecting user data.

Cryptographic Suites Definition

A cipher suite specifies the complete set of cryptographic algorithms used.

Components of an IPsec/IKE Suite

Component Example

Encryption Algorithm AES-128, AES-256

Integrity Algorithm HMAC-SHA256
DH Group ECDH Group 19
PRF SHA-based PRF

NIST Suite B Recommendations

Recommended algorithms include:

Component Recommendation

Key Exchange ECDH P-256
Encryption AES-128 / AES-256
Hashing SHA-256 / SHA-384

Advantages of Elliptic Curve Cryptography

- Strong security
 - Smaller keys
 - Better performance
-

Exam Tip

Purpose of SPI in IPsec

The SPI identifies the correct Security Association.

Receiver Uses:

- SPI

Destination IP

AH/ESP protocol identifier

to locate the SA inside the SAD and determine how to decrypt/authenticate the packet.

5.1 · Intruder Classes and Techniques Intruder Classes

Intruder Type Description

Masquerader Outsider who gains access using a legitimate user account
Misfeasor Legitimate insider who misuses authorised privileges
Clandestine User Gains supervisory control and evades auditing/logging

Intruder Characteristics

Masquerader

- No prior access
- Must bypass authentication first

Misfeasor

- Already trusted internally
- Often most dangerous insider threat

Clandestine User

- Suppresses logs
 - Installs rootkits/backdoors
 - Hides malicious activity
-

Password Learning Techniques

Technique Description

Default Passwords Tries common defaults such as admin/admin
Short Exhaustive Search Brute-force search of all combinations
Dictionary Attack Uses dictionary words and common variations
User Information Collection Uses personal information from social media
Trojan / Keylogger Captures keystrokes directly
Tapping the Line Intercepts authentication traffic

Technique Details

Default Password Attacks

Many devices retain factory credentials.

Examples

- admin/admin
- admin/password

Dictionary Attacks

Common Variations

- Password1!
- p@ssw0rd

Keyloggers

Advantage for Attackers

Bypasses password complexity protections completely.

5.2 · Intrusion Detection Systems (IDS) Statistical Anomaly Detection Threshold Detection

Principle

Counts occurrence frequency of events.

Example

Too many failed logins within a short period.

Advantages

- Simple
- Fast
- Low overhead

Weakness

Same threshold applied to all users.

Result

Heavy users generate false positives.

Profile-Based Detection

Principle

Creates behavioural profile for each user.

Monitored Features

Login times

Commands used

- Files accessed
- Data transfer volumes

Advantages

- Personalised
- More accurate

Weaknesses

- Computationally expensive
 - Requires training/baseline period
-

Rule-Based Detection Signature-Based Detection

Principle

Matches activity against known attack signatures.

Advantages

Low false positives

- Fast for known attacks

Weakness

Cannot detect unknown attacks (zero-days).

Penetration Identification

Principle

Uses expert-system rules to identify attack sequences.

Attack Stages Detected

1. Reconnaissance
2. Exploitation
3. Privilege escalation
4. Lateral movement

Base-Rate Fallacy Definition

Even highly accurate IDS systems generate many false positives when real attacks are rare.

Example Scenario

IDS Accuracy

99%

Daily Events

1,000,000

Real Intrusions

10

Results

Result Type Calculation Approximate Value

True Positives $10 \times 99\%$ 10

False Positives $999,990 \times 1\%$ 9,999

Consequence

Security analysts face:

- Alert fatigue
 - Overwhelming false alarms
 - Missed real attacks
-

Mitigation Methods

Method Purpose

SIEM Correlation Combine alerts from multiple systems

Threat Intelligence Prioritise likely threats

IDS Tuning Reduce false positive rate

Multiple Detection Methods Improve accuracy

Audit Records Native OS Audit Records

Features

- Already generated by OS
- Low additional overhead

Examples

- Windows Event Log

Unix syslog

Detection-Specific Audit Records

Features

- Designed specifically for IDS
- More detailed information

Weakness

Higher overhead

Distributed Intrusion Detection (DIDS) Purpose

Single IDS sensors cannot observe entire enterprise traffic.

Solution

Deploy multiple distributed sensors.

DIDS Architecture

Component Function

Sensor Nodes Monitor local systems/networks

IDS Director Correlates alerts centrally

Benefits

Detects distributed attacks invisible to a single sensor.

Example

Distributed port scanning across subnets.

Challenges

Challenge Description

Communication Security Sensors must communicate securely
Sensor Compromise Attackers may forge alerts
Clock Synchronisation Needed for event correlation
Massive Data Volume Thousands of sensors generate huge logs

SIEM (Security Information and Event Management)

Modern implementation of distributed IDS.

Collects Data From

Firewalls

IDS/IPS

- Servers
- Applications

Functions

Event correlation

- Unified alert generation
-

Example SIEM Platforms

- Splunk
 - IBM QRadar
 - Microsoft Sentinel
-

Honeypots Purpose of Honeypots

Purpose Description

Divert Attackers Draw attention away from real systems
Intelligence Gathering Study attacker tools and techniques
Detect Internal Threats Identify compromised systems probing honeypots
Delay Attackers Buy time for incident response

Low-Interaction Honeypots

Feature Description

Complexity Simulates limited services
Risk Low
Intelligence Value Limited

Feature Description

Setup Difficulty Easy

Examples

- Honeyd
 - Kippo
-

High-Interaction Honeypots

Feature Description

Complexity Real OS and applications
Risk High
Intelligence Value Very high

Requirement

Careful isolation to prevent abuse.

Honeynet

Definition

A network of honeypots simulating an entire enterprise.

Characteristics

Feature Description

Intelligence Value Highest
Complexity Highest
Resource Requirement Very high

Exam Tip

Base-Rate Fallacy in IDS

Even highly accurate IDS systems produce overwhelming false positives when real attacks are rare.

Impact

Analysts become overwhelmed and may miss genuine attacks.

Mitigation

- SIEM correlation
- IDS tuning
- Threat intelligence prioritisation

5.3 · Intrusion Prevention Systems (IPS) IDS vs IPS

IDS IPS

Detects and alerts	Detects and blocks
Passive monitoring	Inline active protection
Uses mirrored traffic	All traffic passes through IPS

IPS Deployment Types Network-Based IPS (NIPS)

Deployment

Placed at network choke points.

Capabilities

Drop packets
Reset TCP sessions

- Block IP addresses

Host-Based IPS (HIPS)

Deployment

Installed on individual hosts.

Monitors

- System calls
- File changes
- Network connections

IPS Detection Methods

Method Characteristics

Signature-Based	Fast, accurate for known attacks
Anomaly-Based	Detects unknown attacks
Policy-Based	Blocks protocol violations

IPS Challenges

False positives are more dangerous than IDS because legitimate traffic may be blocked.

Therefore

IPS systems require careful tuning.

5.4–5.9 · Firewalls, DMZ, UTM, DLP, DPI

Firewall Access Control Techniques

Technique Purpose

Service Control	Controls accessible services
Direction Control	Controls traffic direction
User Control	Controls access by user identity
Behaviour Control	Controls how services are used

Firewall Types Packet Filtering Firewall

Feature Description

OSI Layer	Layer 3/4
Inspection	Per-packet only
State Tracking	■ No
Performance	Fast

Weakness

Cannot inspect application content.

Stateful Inspection Firewall

Feature Description

Tracks Connections

■ Yes

Session Validation ■ Yes

Benefit

Prevents session hijacking.

Application-Level Gateway (Proxy Firewall)

Feature Description

OSI Layer Layer 7

Inspection Full application content

Security Level Highest

Speed Slowest

Circuit-Level Gateway

Feature Description

OSI Layer Layer 5

Inspection TCP connection only

Example Protocol SOCKS

Bastion Host

Definition

Highly hardened host positioned at a critical security point.

Characteristics

- Minimal services installed

Extensive logging

Frequently audited

DMZ (Demilitarized Zone)

Definition

Separate network segment between Internet and internal LAN.

Typical DMZ Servers

- Web servers
 - Email servers
 - DNS servers
-

DMZ Security Benefit

Compromise of DMZ systems does NOT directly expose the internal network.

DMZ Traffic Flow

```
Internet
↓
Boundary Router
↓
External Firewall
↓
DMZ (Web / Mail / DNS)
↓
Internal Firewall
↓
Protected LAN
```

Unified Threat Management (UTM) Definition

Single appliance integrating multiple security functions.

UTM Features

- Firewall
- IDS/IPS
- Antivirus gateway

Web filtering

Anti-spam

- VPN
 - Application control
-

UTM Advantages

- Simpler management
 - Centralised security platform
-

UTM Weaknesses

Weakness Description

Single Point of Failure Entire security stack affected
Performance Bottleneck Heavy processing load

Data Leakage Prevention (DLP) Purpose

Prevents sensitive information from leaving the organisation.

Detects

- Credit card numbers
 - National IDs
 - Classified documents
-

Monitors Channels

- Email

Web uploads

File transfers

Deep Packet Inspection (DPI) Definition

Examines full packet content, not just headers.

DPI Capabilities

Capability Description

Application Identification Detects apps on non-standard ports
Malware Detection Finds threats inside allowed traffic
Policy Enforcement Enables application-level control

DPI Usage

Core technology behind:

- Next-Generation Firewalls (NGFW)
-

Exam Tip

Why Organisations Need Firewalls

Firewalls establish a controlled security perimeter between internal and external networks.

Benefits

- Protect internal assets
- Enforce security policies
- Control inbound/outbound traffic

Provide monitoring and logging points

6.1.1 · Internet Mail Architecture Overview

Internet email systems consist of five major components working together to send, relay, deliver, and store messages.

The 5 Main Components

Component Full Name Function

MUA Message User Agent User email client

MSA Mail Submission Agent Accepts outgoing mail from users
MTA Message Transfer Agent Relays email between servers
MDA Mail Delivery Agent Delivers mail to mailbox
MS Message Store Stores messages until retrieval

1. Message User Agent (MUA)

Purpose

User-facing email application.

Functions

- Compose email
- Send email
- Receive email
- Display email

Examples

- Outlook
- Apple Mail
- Gmail Web App
- Thunderbird

Connections

Purpose Protocol/Port

Outgoing Mail MSA via port 587
Incoming Mail IMAP or POP3

2. Mail Submission Agent (MSA)

Purpose

Accepts outgoing mail from MUAs and injects it into the mail system.

Characteristics

Feature Description

Port 587
Authentication Required
Function Validates and forwards messages

Important Difference

MSA MTA

Client submission Server-to-server relay
Port 587 Port 25

3. Message Transfer Agent (MTA)

Purpose

Transfers email between mail servers.

Functions

- SMTP relay
- DNS MX record lookup
- Message routing

Protocol

SMTP over port 25.

Examples

- Postfix
- Sendmail
- Exim

Microsoft Exchange

4. Mail Delivery Agent (MDA)

Purpose

Delivers mail into recipient mailbox.

Additional Functions

- Spam filtering
- Antivirus scanning

- User filtering rules

Examples

Procmail

Dovecot LDA

5. Message Store (MS)

Purpose

Stores messages until user retrieval.

Storage Formats

Format Description

mbox Single file for all mail
Maildir Separate file per message

Retrieval Protocols

Protocol Features

IMAP Synchronised multi-device access
POP3 Download and optionally delete

Complete Email Flow

MUA → MSA → MTA(s) → MDA → Message Store → MUA

Exam Tip

Five Main Components of Email Architecture

1. MUA — compose/read email
 2. MSA — validate and inject mail
 3. MTA — relay mail via SMTP
 4. MDA — deliver to mailbox
 5. MS — store mail until retrieval
-

6.1.2 · Email Formats — RFC 5322 and MIME RFC 5322 Email Format Structure of an Email Message

An email consists of:

1. Envelope
 2. Headers
 3. Body
-

Components

Component Purpose

Envelope SMTP routing information

Component Purpose

Headers Structured metadata
Body Actual message content

Important RFC 5322 Headers

Header Purpose

From Visible sender
To Recipient
Subject Message subject
Date Timestamp
Message-ID Unique message identifier
In-Reply-To Reply tracking
References Thread tracking
Received Added by each MTA during relay

Envelope From vs Header From

Type Purpose

Envelope From Used for routing and SPF
Header From Visible sender shown to user

Security Issue

Attackers may spoof Header From while using a valid Envelope From.

Solution

DMARC alignment requires them to match.

MIME (Multipurpose Internet Mail Extensions) Purpose of MIME

RFC 5322 supports only 7-bit ASCII text.

MIME extends email to support:

- Attachments
 - Images/audio/video
 - HTML email
 - Non-English characters
 - Multi-part messages
-

MIME Headers Content-Type

Specifies media type.

Examples

Type Purpose

text/plain	Plain text
text/html	HTML email
image/jpeg	Image
application/pdf	PDF attachment
multipart/mixed	Multiple attachments
multipart/alternative	Multiple representations

Content-Transfer-Encoding

Specifies transport encoding.

Encoding Purpose

7bit	ASCII text
quoted-printable	Mostly text with escapes
base64	Binary attachment encoding

Content-Disposition

Determines display behaviour.

Value Meaning

inline	Display directly
attachment	Download as file

Multipart MIME Types multipart/alternative

Contains multiple versions of same content.

Example

- Plain text version
- HTML version

Rule

Last part is preferred.

multipart/mixed

Contains independent parts.

Example

- Email body
 - File attachments
-

MIME and S/MIME

S/MIME uses MIME structure to carry:

- Digital signatures
 - Encrypted content
-

6.1.3–6.1.5 · Email Threats, S/MIME, and PGP Email Threats

Security Goal Threat

Authenticity	Phishing, spoofing
Integrity	Message modification
Confidentiality	Eavesdropping, mailbox theft
Availability	Spam floods, DoS

S/MIME

Security Services Provided

Service Mechanism

Authentication Digital signatures
Confidentiality Encryption
Integrity Signature verification
Non-repudiation Private-key signatures

S/MIME Trust Model

Uses hierarchical PKI with X.509 certificates issued by trusted Certificate Authorities.

Example Certificate Authorities

- DigiCert
 - Comodo
 - IdenTrust
-

S/MIME Signature Process

Steps

1. Sender hashes message
2. Hash encrypted with sender's private key
3. Signature attached to message

Recipient Verification

1. Recipient decrypts signature using sender public key
2. Recipient recomputes hash
3. Hashes compared

Result

Authenticity and integrity verified.

S/MIME Encryption Process

Steps

1. Generate random symmetric session key
2. Encrypt message body with session key
3. Encrypt session key using recipient public key

Recipient Process

1. Decrypt session key using private key
 2. Decrypt message body
-

PGP (Pretty Good Privacy) Trust Model

Uses a decentralised Web of Trust.

Principle

Users sign each other's public keys.

PGP vs S/MIME

Feature S/MIME PGP

Trust Model	Hierarchical PKI	Web of Trust
Certificates	X.509	OpenPGP
Typical Usage	Enterprise	Community/personal
Central Authority Required	Not required	

Common Features

Both provide:

- Authentication
 - Integrity
 - Confidentiality
 - Non-repudiation
-

6.2 · DNSSEC, DANE, SPF, DKIM, and DMARC DNSSEC Purpose

Adds digital signatures to DNS records.

Security Services

Service Provided?

Integrity ☒ Yes

Service Provided?

Authentication ☒ Yes

Confidentiality

☐ No

Prevents

- DNS cache poisoning
- Fake DNS records

Trust Model

Chain of trust:

Root Zone → TLD → Authoritative DNS Server

DANE Full Form

DNS-Based Authentication of Named Entities.

Purpose

Publishes TLS certificate information using DNSSEC-protected TLSA records.

Advantage

Reduces reliance on Certificate Authorities.

SPF (Sender Policy Framework) Purpose

Specifies authorised sending servers for a domain.

Mechanism

Domain publishes DNS TXT record listing permitted IP addresses.

Example SPF Record

```
v=spf1 ip4:203.0.113.0/24 include:_spf.google.com -all
```

SPF Verifies

Sending server IP against:

- Envelope From domain

Limitation

Does NOT protect Header From visible to users.

DKIM (DomainKeys Identified Mail) Purpose

Adds digital signature to email headers and body.

DKIM Process

Signing

1. MSA selects headers/body
2. Computes SHA-256 hash
3. Signs hash using private key
4. Adds DKIM-Signature header

Verification

1. Receiver extracts domain + selector
2. Retrieves public key from DNS
3. Recomputes hashes
4. Verifies signature

DKIM Advantage

Survives forwarding and relay.

DKIM Protects

Visible Header From field.

Example DKIM DNS Query

```
selector1._domainkey.example.com
```

DMARC

Full Form

Domain-based Message Authentication, Reporting, and Conformance.

Purpose

Combines SPF and DKIM with alignment checking.

DMARC Requirements

At least one of:

SPF PASS

- DKIM PASS

AND alignment with Header From domain.

DMARC Policies

Policy Action

none Monitor only

quarantine Treat as suspicious

reject Reject email

DMARC Benefits

- Prevents spoofing
 - Improves phishing protection
 - Provides reporting to domain owners
-

How SPF, DKIM, and DMARC Work Together

Technology Purpose

SPF Validates sending server IP

DKIM Verifies signed message integrity

DMARC Enforces alignment and policy

Exam Tip

SPF + DKIM + DMARC Combined

1. SPF checks sender IP legitimacy
2. DKIM verifies signed message authenticity
3. DMARC requires alignment and defines failure policy

Result

Email domain spoofing becomes extremely difficult.

7.1–7.2 · Wireless Security Fundamentals and Mobile Device Security Why Wireless Networks Are Riskier

Wireless communication introduces additional security risks compared to wired networks.

4 Main Risk Factors

Factor Description

Channel Open broadcast medium

Factor Description

Mobility Devices move across networks

Resources Limited device power and processing

Accessibility Reachable from outside premises

1. Channel

Problem

Wireless transmissions are broadcast openly.

Result

Anyone within range can:

Receive traffic

Monitor communications passively

- Remain undetected

Additional Risk

Directional antennas can greatly extend interception range.

2. Mobility

Problem

Devices constantly change network environments.

Example

- Corporate WiFi
- Public coffee shop WiFi
- Home network

Security Challenge

Consistent policy enforcement becomes difficult.

3. Resources

Problem

Mobile and IoT devices have limited:

CPU

- Memory
- Battery life

Impact

Strong cryptographic operations may:

Reduce performance

Drain battery

Be impractical on small devices

4. Accessibility

Problem

Wireless signals extend beyond physical buildings.

Attack Locations

- Parking lots
- Adjacent buildings
- Long-range antenna positions

Result

Physical perimeter security provides little protection.

Wireless Security Threats Accidental Association

Definition

A device unintentionally connects to the wrong network.

Cause

Neighbouring AP has stronger signal.

Risk

Traffic exposed to unintended network.

Malicious Association

Definition

Attacker creates fake access point (soft AP).

Result

Victim connects to attacker-controlled AP.

Consequence

Full man-in-the-middle capability.

MAC Spoofing

Definition

Attacker clones an authorised MAC address.

Method

1. Passively observe network traffic
2. Copy valid MAC address
3. Impersonate authorised device

Result

MAC filtering is bypassed completely.

Man-in-the-Middle (MITM)

Definition

Attacker sits between client and legitimate AP.

Capabilities

Intercept traffic

Modify traffic

- Record sensitive information
-

Denial of Service (DoS)

Common Wireless DoS Attack

Deauthentication Flood

Attacker sends fake deauthentication frames repeatedly.

Effect

Clients disconnect continuously.

Reason Attack Works

802.11 management frames were originally unauthenticated.

Solution

802.11w — Management Frame Protection

Protects deauthentication/disassociation frames.

Mobile Device Security Strategy 1. Device Security

Security Measure Purpose

Auto-lock Prevent unauthorised access
Strong PIN/password Improve authentication strength
Biometrics Secondary authentication
Remote wipe Protect lost/stolen devices
Full-disk encryption Protect stored data

2. Application Security

Security Measure Purpose

Trusted app stores only Reduce malware risk
Review app permissions Limit unnecessary access
OS/app updates Patch vulnerabilities
Avoid rooting/jailbreaking Preserve OS protections

Rooting/Jailbreaking Risk

Removes built-in operating system security controls.

3. Network Security

Security Measure Purpose

VPN on public networks Encrypt traffic
Disable auto-connect Prevent accidental association

Prefer cellular for sensitive work Avoid public WiFi risks
Verify TLS certificates Prevent MITM attacks

4. Data Security

Security Measure Purpose

Avoid storing sensitive data locally Reduce exposure
Containerisation Separate work/personal data
Restrict personal cloud backups Prevent data leakage

Containerisation

Purpose

Separates:

- Corporate data
- Personal user data

Benefit

Improves enterprise control and security.

Mobile Device Management (MDM) Definition

Centralised management platform for enterprise mobile devices.

MDM Functions

Function Purpose

Enforce security policies Maintain compliance
Remote wipe Protect lost devices
App management Control software installation
Compliance monitoring Detect insecure devices

Importance

Essential for managing large corporate mobile fleets.

7.3–7.4 · IEEE 802.11 Overview and 802.11i (WPA2/RSN) IEEE 802.11 Key Services

Service Description

Association Connect station to AP
Authentication Verify station identity
Privacy Provide confidentiality
MSDU Delivery Deliver data frames

Association

Definition

Process of linking a station (STA) to an access point (AP).

Important Rule

A station can associate with only ONE AP at a time.

Authentication

Purpose

Verify station identity before access is granted.

Older Methods

Method Security

Open Authentication No security
Shared Key (WEP) Broken

Modern Method

802.1X authentication in RSN/WPA2 Enterprise.

Privacy

Purpose

Protect confidentiality of wireless traffic.

Evolution of Wireless Security

Standard Characteristics Status

WEP RC4 + weak IV reuse Broken
WPA TKIP interim fix Deprecated
WPA2 (802.11i) AES-CCMP Current minimum
WPA3 SAE + forward secrecy Latest

WEP (Wired Equivalent Privacy) Problems

- Shared static keys
 - Weak IV reuse
 - RC4 vulnerabilities
-

Result

Keys recoverable within minutes.

WPA

Improvement Over WEP

Introduced TKIP:

- Per-packet key mixing
- Better integrity protection

Status

Deprecated — WPA2 minimum recommended.

WPA2 / IEEE 802.11i (RSN) Features

Feature Description

Encryption AES-CCMP
Authentication 802.1X or PSK
Enterprise Support RADIUS authentication

WPA3

Improvements

Improvement Benefit

SAE Prevents offline dictionary attacks
Forward secrecy Protects past sessions
OWE Encryption for open networks
192-bit mode Higher security level

IEEE 802.11i — 5 Phases of RSN Operation Phase 1 — Discovery

Purpose

Client discovers available APs and capabilities.

Discovery Methods

Method Description

Passive Scanning Reads Beacon frames
Active Scanning Sends Probe Requests

Information Exchanged

RSN Information Element (RSN IE):
Supported cipher suites
Authentication methods

Phase 2 — Authentication

Mechanism

802.1X authentication via RADIUS server.

Roles

Role Function

Station Client
AP Authenticator
RADIUS Server Authentication server

Result

Master Session Key (MSK) established.

Phase 3 — Key Generation and Distribution Key Hierarchy

MSK → PMK → PTK + GTK

Key Definitions

Key Purpose

PMK Pairwise Master Key

PTK Pairwise Transient Key (unicast traffic)

Key Purpose

GTK Group Temporal Key (broadcast traffic)

PTK Components

Component Purpose

KCK Key confirmation

KEK Key encryption

TK Data encryption

4-Way Handshake

Purpose

Generates PTK and distributes GTK securely.

Phase 4 — Protected Data Transfer Encryption Method

AES-CCMP:

- AES-128 encryption
 - CCM mode
-

Replay Protection

Each frame includes a Packet Number (PN).

Rule

Out-of-order or replayed packets are rejected.

Phase 5 — Connection Termination Termination Messages

Message Purpose

Deauthentication Ends authentication

Disassociation Ends association

Security Improvement — 802.11w

Purpose

Protect management frames against spoofing.

Benefit

Prevents deauthentication flood attacks.

8.1 · Cloud Computing — Elements and Reference Architecture Definition of Cloud Computing

Cloud computing provides on-demand access to shared computing resources over a network.

5 Essential Characteristics (NIST)

Characteristic Description

On-demand self-service Resources provisioned automatically

Broad network access Accessible from many device types

Resource pooling Multi-tenant shared infrastructure

Rapid elasticity Fast scaling up/down

Measured service Usage monitored and billed

1. On-Demand Self-Service

Definition

Users provision computing resources automatically without direct provider interaction.

Example

Launching an AWS EC2 server in seconds without contacting support staff.

2. Broad Network Access

Definition

Cloud services accessible over standard network mechanisms.

Supported Devices

Phones

Tablets

- Laptops
 - Workstations
-

3. Resource Pooling

Definition

Provider resources dynamically shared among multiple customers.

Key Feature

Multi-tenant architecture.

Important Point

Customers generally do NOT control physical resource location.

4. Rapid Elasticity

Definition

Resources scale rapidly according to demand.

Features

- Automatic scaling
 - Appears unlimited
 - Pay only for usage
-

5. Measured Service

Definition

Resource usage automatically monitored and reported.

Benefits

Benefit Description

Transparency Clear billing
Monitoring Usage visibility
Control Efficient resource management

Cloud Service Models SaaS (Software as a Service)

Definition

Use provider applications via browser.

Customer Control

Controlled by User Controlled by Provider

Very little Infrastructure + application

Examples

- Gmail
 - Salesforce
 - Microsoft 365
-

PaaS (Platform as a Service)

Definition

Deploy applications using provider development platform.

Customer Control

Controlled by User Controlled by Provider

Applications/configuration OS/hardware/network

Description

“OS in the cloud.”

Examples

- Heroku

Google App Engine

IaaS (Infrastructure as a Service)

Definition

Provision raw compute, storage, and networking resources.

Customer Control

Controlled by User **Controlled by Provider**

OS, apps, configuration Physical infrastructure

Examples

- AWS EC2
 - Azure Virtual Machines
-

Comparison of Service Models

Model **User** **Control** **Level**

SaaS Lowest

PaaS Medium

IaaS Highest

Cloud Deployment Models Public Cloud

Characteristics

- Available to general public
- Owned by cloud provider
- Shared infrastructure

Limitation

Limited physical/geographic control.

Private Cloud

Characteristics

- Exclusive to one organisation

Maximum control/security

Weakness

Highest cost.

Community Cloud

Characteristics

Shared by organisations with common requirements.

Examples

- Government agencies

Healthcare organisations
Financial institutions

Hybrid Cloud

Definition

Combination of two or more deployment models.

Example

Private cloud handles normal workload; public cloud handles peak demand (“cloud bursting”).

NIST Cloud Reference Architecture The 5 Cloud Actors

Actor **Role**

Cloud Consumer Uses cloud services

Cloud Provider Provides cloud services

Cloud Auditor Independent assessment
Cloud Broker Service intermediary
Cloud Carrier Network/connectivity provider

1. Cloud Consumer

Role

Uses cloud services directly.

Responsibilities

- Select services
 - Maintain provider relationship
 - Consume cloud resources
-

2. Cloud Provider

Role

Makes cloud services available.

Provider Layers

Layer Purpose

Service Layer SaaS/PaaS/IaaS delivery
Resource Abstraction Layer Virtualisation/control

Layer Purpose

Physical Resource Layer Hardware infrastructure

3. Cloud Auditor

Role

Performs independent evaluation of cloud systems.

Types of Audits

- Security audits
 - Performance audits
 - Privacy assessments
-

Importance

Provides objective assurance to:

Customers

Regulators

Compliance bodies

4. Cloud Broker

Role

Intermediary managing cloud services.

Broker Functions

Function Description

Service Intermediation Adds value to services
Service Aggregation Combines multiple services
Service Arbitrage Selects providers dynamically

5. Cloud Carrier

Role

Provides network transport/connectivity.

Examples

ISPs

- Telecommunications providers
-

Exam Tip

Five Actors in NIST Cloud Architecture

1. Cloud Consumer
2. Cloud Provider

- 3. Cloud Auditor
- 4. Cloud Broker
- 5. Cloud Carrier

8.2–8.5 · Cloud Security Risks, Data Protection, and SecaaS Major Cloud Security Risks

Risk Description

Abuse and nefarious use Attackers misuse cloud resources
Insecure APIs Vulnerable cloud interfaces
Malicious insiders Provider staff abuse privileges
Shared technology issues Multi-tenant isolation failures
Account hijacking Stolen cloud credentials

Abuse and Nefarious Use

Problem

Attackers easily register cloud accounts.

Uses

- Spam campaigns
- Malware hosting
- DDoS attacks

Mitigation

Method Purpose

Strong registration checks Prevent fake accounts
Fraud monitoring Detect abuse
Traffic analysis Identify malicious activity

Insecure Interfaces and APIs

Problem

Cloud management relies heavily on APIs.

Risks

Weak authentication

- Injection vulnerabilities
- Unencrypted communication

Result

Compromise of APIs compromises cloud resources.

Malicious Insiders

Problem

Provider administrators may access customer data.

Mitigation

Control Purpose

Access control Restrict privileges
Background checks Reduce insider risk
Separation of duties Prevent abuse
Audit logging Detect misuse

Shared Technology Issues

Problem

Multiple customers share hardware resources.

Examples

- Hypervisors
 - Shared CPU caches
 - Shared GPUs
-

Threat Example

Spectre/Meltdown side-channel attacks.

Risk

VM-to-VM data leakage.

Mitigation

- Hardware isolation
 - Security patching
 - Dedicated instances
-

Account and Service Hijacking

Problem

Attacker gains cloud account credentials.

Consequences

Data theft

Service deletion

- Traffic redirection
- Eavesdropping

Mitigation

Control Purpose

MFA Strong authentication
IP restrictions Limit access locations
Login anomaly detection Detect suspicious access

Cloud Data Protection Data at Rest

Goal

Protect stored data.

Method

Client-side encryption before upload.

Benefit

Even provider insiders cannot read plaintext data.

Data in Transit

Goal

Protect data moving across networks.

Protection Mechanisms

- TLS
- HTTPS
- Secure inter-service communication

Important Requirement

Always verify certificate validity.

Data in Use

Problem

Data must often be decrypted for processing.

Emerging Solutions

Technology Description

Homomorphic Encryption Compute on encrypted data
Confidential Computing Hardware-secured enclaves

Examples of Confidential Computing

- Intel SGX
 - AMD SEV
-

SecaaS (Security as a Service)

Definition

Outsourcing security functions to cloud providers.

Major SecaaS Categories

Category Purpose

IAM Identity and access management
DLP Data loss prevention
Web Security Gateway Web filtering/protection
Email Security Spam/phishing filtering
Security Assessments Vulnerability scanning
Intrusion Management Cloud IDS/IPS
Encryption & Key Management Secure cryptographic services
SIEM Centralised event monitoring
Business Continuity/DR Backup and disaster recovery

Benefits of SecaaS

- Reduced infrastructure costs
- Centralised security management
- Scalability

Access to specialised expertise

9.1–9.2 · Audit vs Assessment, Compliance, and Frameworks IT Security Assessment vs IT Security Audit

Feature IT Security Assessment IT Security Audit

Purpose	Identify weaknesses and risks	Verify compliance against standards
Focus	Current + future security posture	Past performance/compliance
Nature	Risk-based	Standards-based
Independence	required	Not necessarily
Output	Findings + recommendations	Formal audit opinion
Certification	No certification	May lead to certification

IT Security Assessment

Definition

A risk-based review used to identify security weaknesses and prioritise mitigation.

Characteristics

- Can be internal

Focuses on improvement

Identifies vulnerabilities

Verifies remediation effectiveness

Main Goal

Improve the organisation's security posture.

IT Security Audit

Definition

An independent and objective review against defined standards or policies.

Characteristics

- Must be independent
- Formal process
- Compliance-focused
- Produces official opinion

Result

Successful audit may produce certification.

Security Frameworks COBIT 5

Purpose

Framework for enterprise IT governance and management.

5 COBIT Principles

Principle Description

Meeting stakeholder needs IT must deliver value
Covering enterprise end-to-end Governance across entire organisation
Single integrated framework Align with other standards

Holistic approach Multiple enablers work together
Separate governance from management Governance and execution are distinct

Principle 1 — Meeting Stakeholder Needs

Goal

Align IT services with business objectives and stakeholder expectations.

Principle 2 — Covering the Enterprise End-to-End

Goal

Govern all IT functions across the whole enterprise.

Principle 3 — Applying a Single Integrated Framework

Goal

Integrate with standards such as:

- ISO 27001
 - NIST
 - COSO
-

Principle 4 — Enabling a Holistic Approach

Uses 7 Enablers

1. Principles/policies
 2. Processes
 3. Organisational structures
 4. Culture/ethics
 5. Information
 6. Services/infrastructure
 7. People/skills
-

Principle 5 — Separating Governance from Management

Governance Management

Sets objectives Executes objectives
Board responsibility Executive responsibility

COSO Framework

Purpose

Enterprise Risk Management (ERM).

4 Objectives

Objective Description

Strategic High-level goals
Operations Efficient operations
Reporting Reliable reporting
Compliance Legal/regulatory compliance

Key Feature

Uses 8 interrelated components for risk management.

ISO/IEC 27001

Purpose

International standard for Information Security Management Systems (ISMS).

Key Features

Certifiable standard

- Risk-based approach
 - Continuous improvement
-

PDCA Cycle

Stage Purpose

Plan Establish ISMS
Do Implement controls

Check Monitor/evaluate
Act Improve continuously

ISO/IEC 27002

Purpose

Detailed security controls supporting ISO 27001.

2022 Version

93 controls

4 control domains

NIST SP 800-53

Purpose

US federal security control catalogue.

Examples of Control Families

Family Purpose

Access Control Restrict access
Audit Logging/monitoring
Configuration Management Secure configurations
Incident Response Handle security incidents
Risk Assessment Identify/manage risks
System Communications Protection Secure communications

SOC Reports SOC 1

Focus

Controls affecting financial reporting.

SOC 2

Focus

Trust Services Criteria.

5 Trust Service Categories

1. Security
 2. Availability
 3. Processing Integrity
 4. Confidentiality
 5. Privacy
-

SOC 3

Purpose

Public summary version of SOC 2.

Audience

General public/customers.

Exam Tip

5 COBIT Principles

1. Meeting stakeholder needs
 2. Covering enterprise end-to-end
 3. Applying a single integrated framework
 4. Enabling a holistic approach
 5. Separating governance from management
-

9.3–9.4 · Planning and Conducting an IT Infrastructure Audit 7 IT Infrastructure Domains

Domain Main Focus

User Domain End users

Domain Main Focus

Workstation Domain End-user devices

LAN Domain Local network
LAN-to-WAN Domain Perimeter security
WAN Domain External connectivity
Remote Access Domain VPN/remote users
System/Application Domain Servers/apps/databases

1. User Domain

Includes

- Employees
- Contractors
- Guests

Security Concerns

Password sharing

Social engineering

- Insider threats

Controls

- Authentication
 - Acceptable Use Policies (AUPs)
-

2. Workstation Domain

Includes

- Desktops
- Laptops
- Removable storage

Controls

- Patch management
 - Disk encryption
 - Vulnerability scanning
 - Endpoint protection
-

3. LAN Domain

Includes

- Switches
- Wireless APs
- Local servers

Controls

VLAN configuration

Port security

Monitoring

4. LAN-to-WAN Domain

Description

Primary security perimeter.

Includes

- Routers
- Firewalls
- IDS/IPS
- DMZ

Audit Activities

Firewall rule review

- IDS tuning checks
 - DMZ verification
-

5. WAN Domain

Includes

ISP links

MPLS

- VPN tunnels

Controls

- Encryption
 - Redundancy
 - SLA monitoring
-

6. Remote Access Domain

Includes

- VPN systems
- Remote users
- RADIUS authentication

Controls

- MFA
 - Session timeout
 - Device health checks
-

7. System/Application Domain

Most Sensitive Domain

Contains critical data and services.

Includes

Servers

- Applications
- Databases
- Mainframes

Controls

- Patch management

Access control

Backup verification

- Code review
-

IT Audit Process Phase 1 — Planning

Activities

Activity Purpose

Define scope Identify systems/timeframe
Identify standards Determine audit criteria
Build audit team Assign responsibilities
Request documentation Gather evidence sources

Activity Purpose

Create audit programme Plan audit activities

Phase 2 — Conducting the Audit Establish Security Baseline

Question

“What SHOULD exist?”

Gap Analysis

Compare

Current State Required State

What exists What should exist

Evidence Collection Methods

- Configuration files
 - Logs
 - Interviews
 - Observation
 - Screenshots
 - System outputs
-

Evidence Evaluation

Goal

Determine whether controls meet requirements.

Common Safeguards Verified

Safeguard Purpose

Segregation of duties Prevent fraud
Rotation of duties Detect abuse
Least privilege Limit access
Mandatory vacations Reveal fraud
Dual control Require two people for sensitive tasks

9.5 · Writing the IT Infrastructure Audit Report Purpose of the Audit Report

Primary deliverable communicating findings to:

- Management
- Board of directors
- Regulators

External parties

Report Writing Requirements

Clear

Accurate

- Complete
 - Objective
-

Audit Report Structure

1. Executive Summary

Audience

Senior management.

Contents

- Scope

Overall opinion

Key findings

Major risks

Important Point

Should be readable in ~2 minutes.

2. Introduction / Background

Includes

Section Description

Scope Systems/time period covered
Objectives Audit goals
Methodology Audit methods used
Standards Frameworks applied
Limitations Constraints encountered
Audit team Independence and membership

3. Findings

Core Section of the Report

Each finding includes:

Element Meaning

Condition What was found
Criteria What should exist
Cause Why issue exists
Effect Risk/impact created

Important Rule

All findings must be evidence-based.

4. Risk Ratings

Rating Meaning

Critical Immediate severe risk
High Significant risk
Medium Moderate risk
Low Minor issue

Purpose

Helps prioritise remediation effort.

5. Recommendations

Requirements

Specific

- Actionable
- Practical
- Risk-based

Goal

Address root cause, not just symptoms.

6. Management Response

Purpose

Management formally responds to findings.

Possible Responses

Response Meaning

Accept risk No remediation planned
Remediate Fix issue with timeline
Dispute Challenge finding

Importance

Creates accountability and tracking.

7. Conclusion

Auditor's Overall Opinion

Opinion Meaning

Unqualified Controls adequate

Opinion Meaning

Qualified Mostly adequate except some areas
Adverse Controls inadequate
Disclaimer Unable to form opinion

Audit Report Writing Principles Objectivity

Rule

Only report what evidence supports.

Clarity

Rule

Write appropriately for audience.

Example

Audience Writing Style

Executives High-level/simple
IT staff Technical detail

Completeness

Rule

Include ALL significant findings.

Timeliness

Rule

Issue report promptly before findings become outdated.

Exam Tip

Key Sections of an Audit Report

1. Executive Summary
 2. Introduction/Background
 3. Findings
 4. Risk Ratings
 5. Recommendations
 6. Management Response
 7. Conclusion
-

10.1 · Compliance Basics and Maintaining IT Compliance 3 Audit Objectives

Objective Purpose

Examine policies and procedures Ensure security documentation exists and is approved
Verify controls exist Confirm controls are actually implemented
Verify effectiveness and monitoring Ensure controls work continuously

1. Examine Security Policies and Procedures

Goal

Verify that security policies:

- Exist

Are documented

Are current

- Are management-approved
-

2. Verify Existence of Controls

Goal

Confirm that technical and administrative controls supporting policies are implemented.

Examples

- Firewalls
 - MFA
 - Encryption
 - Logging
 - Access control
-

3. Verify Effective Implementation and Monitoring

Goal

Ensure controls operate continuously — not only during audits.

Includes

- Monitoring
- Logging
- Alert review

Continuous compliance checks

4 Components of Maintaining Compliance

Component Purpose

Regular assessment Test security continuously
Configuration/control management Prevent configuration drift
Change management Secure system changes
Annual audit Independent formal assurance

1. Regular Assessment

Purpose

Continuously evaluate security posture.

Activities

- Vulnerability scanning
- Penetration testing
- Configuration review

Security testing

Important Point

Threats evolve over time; controls must be reassessed regularly.

2. Configuration and Control Management

Purpose

Maintain approved secure baselines.

Key Activities

Activity Purpose

Baseline maintenance Standardise configurations
Drift detection Detect unauthorised changes
Control review Ensure controls remain effective

Supporting Tools

- SIEM
 - CMDB
 - Configuration management systems
-

3. Change Management

Purpose

Ensure changes do not introduce vulnerabilities.

Change Management Lifecycle

1. Change request
 2. Impact assessment
 3. Approval
 4. Testing
 5. Implementation
 6. Post-change review
-

4. Annual Audit

Purpose

Provide independent assurance.

Benefits

Regulatory compliance

- Customer assurance
 - Risk validation
 - Management confidence
-

10.1.4 · Compliance within the User Domain User Domain

Includes

- Employees
- Contractors
- Temporary staff
- Guests

Key Risk

Humans are often the weakest security link.

Acceptable Use Policy (AUP)

Purpose

Defines permitted and prohibited use of IT resources.

Typical AUP Contents

Area Examples

Permitted use Business use policies
Prohibited actions Illegal downloads, credential sharing
Data handling Sensitive data requirements
Monitoring notice User activity monitoring
Consequences Disciplinary actions

Important Requirement

All users must sign the AUP.

User Awareness Training

Topics Covered

- Phishing recognition
- Password hygiene
- Social engineering

Data handling

Incident reporting

Compliance Requirement

Training completion must be documented.

Password Policy Compliance

Typical Requirements

Requirement Example

Minimum length 12+ characters
Complexity Upper/lower/symbols
Expiry Periodic rotation
Reuse prevention Cannot reuse old passwords

Audit Activity

Review Active Directory or IdP password configuration.

Least Privilege Access Control

Principle

Users receive only access required for their role.

RBAC (Role-Based Access Control)

Definition

Permissions assigned based on job role.

Audit Checks

- Excessive privileges
 - Dormant accounts
 - Privileged accounts
-

User Account Management

Joiner-Mover-Leaver Process

Stage Action

Joiner Create account
Mover Adjust permissions
Leaver Disable/delete account

Common Audit Finding

Active accounts belonging to ex-employees.

Monitoring and Logging

Logged Activities

- Login times
- Systems accessed
- Data downloads

Audit Checks

- Logging enabled
- Logs securely stored

- Retention policy followed
-

10.1.5 · Compliance within the Workstation Domain Workstation Domain

Includes

- Desktops
- Laptops
- Tablets

Endpoint devices

Patch Management

Requirements

Patch Type Timeline

Critical patches Within 72 hours
Standard patches Within 30 days

Common Tools

WSUS

- SCCM
- Endpoint management platforms

Audit Activity

Identify missing patches and critical CVEs.

Antivirus / Antimalware

Requirements

- Installed on all endpoints
- Real-time protection enabled
- Daily signature updates

Audit Evidence

Centralised AV compliance dashboard.

Full-Disk Encryption

Purpose

Protect data if device is lost or stolen.

Technologies

OS Encryption Tool

Windows BitLocker
macOS FileVault
Linux LUKS

Important Point

Unencrypted laptops are critical findings.

Screen Lock and Auto-Lock

Requirement

Automatic lock after inactivity (5–10 minutes).

Purpose

Prevent unauthorised physical access.

Baseline Configuration

Definition

Approved Standard Operating Environment (SOE).

Security Requirements

- Firewall enabled
 - Local admin restricted
 - Unnecessary software removed
-

Removable Media Control

Goal

Prevent malware introduction and data exfiltration.

Controls

- USB restrictions
- Encrypted USB devices only

DLP monitoring

Software Whitelisting

Definition

Only approved applications may execute.

Examples

- AppLocker
- SELinux

Benefit

Reduces attack surface significantly.

10.1.6 · Compliance within the LAN Domain LAN Domain

Includes

- Switches
 - Wireless APs
 - Internal servers
 - Cabling infrastructure
-

Network Segmentation / VLANs

Purpose

Separate sensitive systems from general traffic.

Benefits

- Limits lateral movement
- Improves containment
- Enhances security control

Audit Activities

- Review VLAN configuration
 - Verify ACLs between segments
-

Switch Port Security

Controls

Control Purpose

MAC limits Prevent rogue devices
Disable unused ports Reduce attack surface
802.1X Require authentication

Audit Checks

Are unused ports disabled?

Is port security configured?

Wireless Security

Requirements

- WPA2/WPA3 Enterprise
- 802.1X authentication

Separate guest VLAN

Rogue AP detection

Audit Activities

- Wireless survey
 - Verify authentication configuration
-

Server Hardening

Requirements

- CIS benchmark compliance
- Minimal services
- Host firewall enabled

Restricted admin access

Audit Tools

- CIS benchmark tools
 - Nmap scans
-

Network Monitoring

Components

- SNMP monitoring
- IDS sensors
- Traffic monitoring

Purpose

Detect anomalies such as malware or data exfiltration.

Physical Security

Requirements

- Locked server rooms
- Access logging
- Protected network closets

Audit Activities

- Inspect physical controls
 - Review access logs
-

10.1.7 · Compliance within the LAN-to- WAN Domain LAN-to-WAN Domain

Description

Perimeter between internal network and Internet.

Includes

Firewalls

Routers

- IDS/IPS
 - DMZ
-

Firewall Rule Review

Requirements

Quarterly reviews minimum

Default deny policy

- Remove unused rules

Dangerous Rule Example

any → any

Audit Activities

- Export ruleset
 - Verify deny-all rule
 - Identify excessive access
-

IDS/IPS Deployment and Tuning

Requirements

- Up-to-date signatures
- Alert tuning
- Alert review process

Audit Activities

- Check signature updates
- Review alerts

- Test detection capability
-

DMZ Architecture

Purpose

Isolate public-facing servers from internal LAN.

Common DMZ Systems

- Web servers
- Email servers
- DNS servers

Audit Checks

- No direct DMZ-to-LAN routing
 - Hardened servers
 - Patch compliance
-

Internet Access Control

Controls

Control Purpose

Web proxy Control outbound traffic
URL filtering Block malicious sites
DNS filtering Block malicious domains
SMTP restrictions Prevent unauthorised mail sending

NAT and Address Management

Purpose

Hide internal RFC1918 addresses from Internet.

Audit Activity

Ensure internal IPs are not externally exposed.

Change Management for Perimeter Devices

Requirement

All firewall changes follow formal change management.

Audit Checks

- Approved change requests
 - Current documentation
 - Emergency change process
-

10.1.8 · Compliance within the WAN Domain WAN Domain

Includes

- ISP connections
 - MPLS
 - Internet circuits
 - VPN tunnels
-

Service Provider SLAs

SLA Areas

Area Example

Availability 99.9% uptime
Latency Maximum delay
Bandwidth Guaranteed throughput

Audit Activity

Review SLA compliance and penalties.

Encryption of WAN Links

Requirement

Sensitive WAN traffic must be encrypted.

Important Point

MPLS provides isolation — NOT encryption.

Solutions

- IPsec
 - TLS
-

Redundancy and Resilience

Goal

Prevent single points of failure.

Methods

- Multiple ISPs

Diverse physical paths

BGP failover

Audit Activity

Simulate link failure and verify failover.

Dedicated Circuits vs Internet VPN

Dedicated Circuits Internet VPN

Higher reliability Lower cost

Expensive Flexible

Dedicated Circuits Internet VPN

Guaranteed bandwidth Depends on Internet

Third-Party and Partner Connections

Risk

Partner security may be weaker than yours.

Controls

- Strict firewall rules
- Minimum security requirements
- Limited access

Audit Activities

- Review agreements
 - Verify firewall restrictions
-

10.1.9 · Compliance within the Remote Access Domain Remote Access Domain

Covers

- Home workers
- Travellers
- Remote employees

Risk

Connections occur over untrusted networks.

VPN for All Remote Access

Requirement

All remote access must use encrypted VPN tunnels.

VPN Types

SSL/TLS VPN

- IPsec VPN
-

Split vs Full Tunneling

Type Description

Split tunneling Only corporate traffic via VPN

Full tunneling All traffic via VPN

Security

Full tunneling is more secure.

Multi-Factor Authentication (MFA)

Requirement

VPN access must require MFA.

Authentication Factors

Factor Type Example

Something you know Password
Something you possess OTP app/token
Something you are Biometric

Audit Checks

- MFA enforced?
 - Exempt accounts?
 - Bypass rules?
-

Client Device Posture Checking (NAC)

Checks Before Access Granted

- Patch level
- Antivirus status
- Disk encryption
- Firewall enabled

Non-Compliant Devices

Placed in quarantine network.

Session Management

Requirements

Inactivity timeout
Maximum session duration

- Session logging

Logged Information

User

- Time
- Location
- Duration
- Resources accessed

Authentication Server Security (RADIUS)

Requirements

- Hardened
- Patched
- Monitored
- High availability

Critical Point

If RADIUS fails, remote access may fail.

Remote Access Policy

Defines

- Who may connect
- Allowed device types

Accessible resources

Usage conditions

Important Rule

No remote access from public/shared computers.

Exam Tip

Key Remote Access Compliance Requirements

1. VPN encryption
2. MFA enforcement

3. NAC posture checking
 4. Session timeout/logging
 5. Hardened RADIUS server
 6. Written remote access policy
-

10.2–10.3 · Audit Tools, Vulnerability Assessment, and Hardening Common Audit and Security Tools

Tool Purpose

Nmap Network discovery and scanning
Wireshark Packet analysis
Metasploit Penetration testing
Nessus/OpenVAS Vulnerability scanning

Nmap

Purpose

Network discovery and security auditing.

Key Features

Option Purpose

- sS SYN scan
 - sV Service version detection
 - O OS detection
 - script NSE scripting engine
-

Example Command

```
nmap -sS -sV -O 192.168.1.0/24
```

Wireshark

Purpose

Capture and analyse network traffic.

Uses

- Verify encryption
 - Detect cleartext protocols
 - Traffic baselining
 - Incident investigation
-

Key Features

- Display filters
 - Protocol decoding
 - Stream following
-

Metasploit

Purpose

Framework for penetration testing.

Uses

- Exploit testing

Vulnerability validation
Security research

Important Requirement

Must have written authorisation before use.

Nessus / OpenVAS

Purpose

Automated vulnerability scanning.

Strengths

- Fast
- Comprehensive

Detects known CVEs

Limitation

Cannot identify custom application logic flaws.

Vulnerability Assessment Definitions

Term Definition

Asset Valuable system/data
Vulnerability Weakness/ flaw
Threat Potential danger
Exploit Technique/code abusing a vulnerability
Risk Likelihood $\times$ impact

Infrastructure Hardening Remove Unnecessary Services

Purpose

Reduce attack surface.

Rule

Disable anything not required.

Remove Build Tools

Examples

- Compilers
- Debuggers
- Package managers

Reason

Attackers can misuse them on compromised systems.

Least Privilege for Services

Rule

Services should run as dedicated low-privilege accounts.

Avoid

Running services as:

- root

SYSTEM

Patch Management

Requirement

Critical CVEs patched within 72 hours.

Key Activities

- Asset inventory
 - Advisory monitoring
 - Systematic deployment
-

Secure Cryptography

Recommended

Category Recommendation

Encryption AES-256

Category Recommendation

Public key RSA-2048+

Hashing SHA-256+

TLS TLS 1.2/1.3

Disable

- DES
 - 3DES
 - RC4
 - MD5
 - SHA-1
-

Host Firewall

Requirement

Enable OS-level firewall on all systems.

Rule

Allow only required inbound ports.

Exam Tip

4 Components of Maintaining Compliance

1. Regular assessments
2. Configuration/control management
3. Change management
4. Annual comprehensive audit